

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)
Department of Computer Science and Engineering
ASSESSMENT TOOL 2 – INCIDENT ANALYSIS (ROOT CAUSE & RISK)

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 2
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Incident Investigation, Root Cause Analysis and Risk Assessment.		
Student Name:	V Lokesh kumar	Reg. No.:	192521170
Section / Batch:	Slot C	Date:	27/08/26

Instructions to Students

- Review the given security incident scenario, evidence, logs and indicators carefully before beginning the analysis.
- Identify the incident sequence, affected assets, relevant indicators and supporting evidence without making unsupported assumptions.
- Determine the root cause by linking observed events, vulnerabilities and contributing conditions in a logical sequence.
- Assess identified risks based on likelihood, severity and potential technical or operational impact.
- Present investigation findings, root-cause reasoning and risk assessment clearly with appropriate technical justification.

Question Type	Focus Area	Questions	Marks
INCIDENT ANALYSIS	Investigation & Risk	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

Campus Network Security Incident Response

1. Incident Investigation

The campus-network dashboard shows a **student device scanning multiple internal VLANs**. This is suspicious because a normal student device should generally communicate only with authorized services and its assigned network.

The investigation should begin by identifying:

- **Source device:** IP address, MAC address, hostname and switch/AP port.
- **User identity:** Student account associated with the device.
- **Target VLANs:** Identify which student, faculty, laboratory, server or administration VLANs were scanned.
- **Scan activity:** Check destination IPs, ports, protocols and scan frequency.
- **Time and duration:** Establish when the scanning started and whether it is still active.
- **Authentication logs:** Review DHCP, NAC, RADIUS, wireless-controller and switch logs.
- **Security alerts:** Correlate IDS/IPS, firewall and centralized SIEM logs.
- **Endpoint status:** Determine whether the device contains malware, unauthorized tools or compromised credentials.

The device should initially be treated as a **potentially compromised endpoint**, rather than immediately assuming that the student is malicious.

2. Incident Response Plan

Step 1 – Detect and Alert

IDS/IPS detects unusual horizontal scanning across multiple VLANs and generates an alert.

Step 2 – Identify

Determine the device's IP/MAC address, switch port or wireless AP, logged-in user and affected VLANs.

Step 3 – Contain

Immediately restrict the suspicious device using **NAC quarantine** or place it into an isolated remediation VLAN. Firewall ACLs should block unnecessary inter-VLAN communication.

Step 4 – Preserve Evidence

Collect firewall logs, IDS/IPS alerts, DHCP records, authentication logs, switch logs and endpoint security logs before making major changes.

Step 5 – Investigate

Determine whether the scan was caused by malware, a compromised account, an unauthorized security tool, misconfiguration or legitimate administrative/security testing.

Step 6 – Eradicate

Remove malware, disable compromised credentials, uninstall unauthorized software and correct configuration weaknesses.

Step 7 – Recover

Patch and restore the endpoint, reconnect it to the normal student VLAN only after security checks pass, and monitor it closely.

Step 8 – Review

Document the incident, root cause, affected systems and lessons learned. Update network rules and security policies where necessary.

3. Root Cause Analysis

Possible root causes include:

1. **Malware infection** – Malware may automatically scan nearby systems to discover vulnerable hosts.
2. **Compromised student credentials** – An attacker may have gained access through stolen credentials.
3. **Unauthorized scanning tools** – A student may intentionally or accidentally run network-scanning software.
4. **Weak VLAN/ACL configuration** – Incorrect inter-VLAN rules may allow students to reach sensitive networks.
5. **Missing endpoint controls** – An unmanaged or unpatched device may have bypassed security requirements.
6. **Improper network segmentation** – Excessive communication between student and critical VLANs increases attack surface.

The root cause should be confirmed using **correlated logs and endpoint forensic evidence**, rather than relying only on the dashboard alert.

4. Risk Assessment

The risk is **high** if the student device can successfully reach faculty, laboratory, server or administration VLANs.

- **Confidentiality:** Unauthorized access could expose student, faculty or administrative information.
- **Integrity:** Attackers could modify systems or services.
- **Availability:** Scanning could precede attacks such as exploitation or denial-of-service.
- **Lateral movement:** Access to multiple VLANs could allow an attacker to move from a compromised student device toward critical servers.

Risk can be reduced by applying **least privilege, network segmentation, continuous monitoring and endpoint security**.

5. Mitigation Strategies

NAC (Network Access Control):

- Authenticate every device before granting network access.
- Verify device security posture.
- Automatically quarantine suspicious or non-compliant devices.
- Place unknown devices into a restricted guest/remediation VLAN.

VLAN Isolation:

- Separate student, faculty, laboratory, server, administration and guest networks.
- Prevent direct student-to-administration/server communication.
- Permit only required traffic through controlled firewalls/ACLs.

IDS/IPS:

- Detect port scanning, unusual traffic and attack patterns.
- IDS provides visibility and alerts.
- IPS can automatically block malicious traffic.
- Correlate alerts with firewall and authentication logs.

Firewall and ACL Controls:

- Apply deny-by-default rules between sensitive VLANs.
- Allow only required ports and services.
- Restrict management interfaces to authorized administrators.

Endpoint Security:

- Keep operating systems and applications patched.
- Use EDR/antimalware.
- Remove unauthorized scanning or hacking tools.
- Check running processes, network connections and persistence mechanisms.

6. Endpoint Remediation

The suspicious endpoint should remain isolated until investigation is complete.

1. Quarantine the device through NAC.
2. Identify the user and preserve relevant logs.
3. Run EDR/antimalware and vulnerability scans.
4. Remove malware or unauthorized software.
5. Patch the operating system and applications.
6. Reset credentials if compromise is suspected.
7. Verify firewall and security configurations.
8. Re-scan the device to confirm that malicious activity has stopped.
9. Return it to the student VLAN only after compliance checks succeed.
10. Continue monitoring for recurring scanning activity.

7. Justification of the Security Controls

NAC + VLAN Isolation + IDS/IPS + Endpoint Remediation provides defense in depth.

- **NAC** controls *who and what* can connect.
- **VLAN isolation** limits *where* a device can communicate.
- **IDS/IPS** detects and blocks *suspicious network behavior*.
- **Firewalls/ACLs** control *allowed communication paths*.
- **Endpoint remediation** removes the *underlying device compromise*.